Open-Source and Third-Party Library Usage Policy

Document ID	ENG-015
Department	Engineering
Document type	Policy
Owner	Principal Architect
Version	1.4
Status	APPROVED
Effective / last reviewed	2025-04-01
Audience	Engineering staff
Related documents	ENG-001, SEC-007, SEC-011

Summary. Sets the rules for using open-source and third-party libraries in Northstar Systems products, including allowed, review-required and prohibited licences, the Open Source Review Board, SBOM generation, vulnerability handling for dependencies, contribution rules and worked examples.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This policy governs how Northstar Systems Private Limited engineering selects, approves, uses, tracks and contributes to open-source software and other third-party libraries. Its goals are to protect the company from licence obligations that could force disclosure of proprietary source code, to keep known vulnerabilities out of the Northstar Nexus Platform, Nexus Connect, Nexus Insight and internal tools, and to give engineers a fast, predictable path for adopting good libraries.

The policy applies to every engineer, contractor and vendor developer who adds or changes a dependency in a Northstar repository. It covers source libraries, frameworks, container base images, build plugins, command line tools bundled in products, and code snippets copied from public sites. It applies to products that are distributed to customers (for example the Nexus Connect gateway components or any installable connector package) and to services that run only in Northstar's own cloud. Commercial third-party software that is bought through NorthBuy is additionally subject to the procurement and third-party security rules; this policy covers its licence terms only where they affect code use.

All legal and licence interpretations in this document are illustrative and to be verified by Legal before external use.

2. Definitions

- **Dependency**: any external software component that the product code uses, directly or indirectly.
- **Direct dependency**: a component named in the project's manifest file.
- **Transitive dependency**: a component brought in by a direct dependency. Transitive dependencies are subject to this policy in the same way as direct ones.

- **Copyleft licence**: a licence that requires derivative works, and sometimes network use, to be released under the same licence.
- **Distributed product**: software that Northstar delivers to customers to run on their own infrastructure, as an installable package, container image, SDK or agent.
- **Hosted service**: software that runs only in Northstar's cloud and is accessed by customers over the network.
- **SBOM**: a Software Bill of Materials, a machine-readable list of all components in a release with versions and licences.
- **Open Source Review Board (OSRB)**: the group that reviews licences needing approval. Members are the Principal Architect (chair), a Legal representative, a Security representative and an engineering manager.
- **Allow list, review list and block list**: the three licence categories in section 4.

3. Roles and Responsibilities

- **Engineer adding a dependency**: checks the licence and vulnerabilities before adding the dependency, and keeps the choice documented in the pull request.
- **Reviewer**: confirms the dependency check as part of code review and does not approve a change that adds a dependency with a blocked licence.
- **Principal Architect**: owns this policy and chairs the OSRB.
- **Legal representative**: interprets licences and approves non-standard terms.
- **Security Champion and Security Operations**: assess vulnerabilities in dependencies and monitor advisories.
- **Release manager**: confirms that an SBOM has been generated and attached before a release is approved.
- **Engineering manager**: ensures the team keeps dependencies current.

4. Licence Categories

Licences are divided into three categories. The category applies to the licence of each dependency, including transitive dependencies.

Category	Licences	Rule
Allowed	MIT, Apache-2.0, BSD-2-Clause, BSD-3-Clause, ISC	May be used without approval, subject to attribution and the checks in section 5
Needs review	LGPL, MPL-2.0, EPL	Must have Open Source Review Board approval before use
Prohibited	AGPL, SSPL, GPL in distributed products, and any licence without clear terms	Must not be used

4.1 Allowed licences

The permissive licences in the allowed list may be used in both distributed products and hosted services. The engineer must still keep the copyright and licence notices and include them in the third-party notices file that ships with the product. Apache-2.0 components that include a NOTICE file must have that notice preserved.

4.2 Licences needing OSRB approval

LGPL, MPL-2.0 and EPL are weak copyleft licences. Their effect depends on how the library is linked and whether it is modified, so a dependency under one of these licences must not be merged until the OSRB has approved it. The request must state the library name and version, the licence, how it will be linked or bundled (dynamic or static, modified or unmodified), whether it will ship in a distributed product, and why a permissively licensed alternative is not suitable. The OSRB may approve with conditions, for example "dynamic linking only, unmodified, in the hosted service only".

4.3 Prohibited licences

AGPL and SSPL are prohibited because their network-use clauses can require disclosure of Northstar's own source code when software is offered as a service. GPL is prohibited in distributed products because distribution would require the product's source code to be offered under GPL terms. Any licence without clear terms is prohibited, including code with no licence file, code that says "free to use" without conditions, and code posted in forums or gists with no stated licence. If an engineer is unsure whether a licence is covered, it is treated as needing review until the OSRB or Legal says otherwise.

GPL tools may be used on a developer machine or in the build environment if the tool's output is not itself a derivative work and nothing from the tool is shipped. Examples include a GPL-licensed command line formatter. Such use should be noted in the pull request. A GPL library must not be linked into or shipped within a distributed product.

4.4 Dual-licensed and multi-licensed components

Where a component is offered under several licences, the team may choose the most permissive licence offered, provided that licence is in the allowed list, and must record the choice. If none of the offered licences is allowed, the component needs OSRB review.

5. Checks Before Adding a Dependency

Before adding a dependency, the engineer must complete the following checks, which are enforced by automated scans in NorthShip and confirmed in code review.

1. **Licence**: identify the licence of the library and its transitive dependencies and confirm the category in section 4.
2. **Vulnerabilities**: no new dependency with an unpatched critical vulnerability may be added. The engineer must run the dependency scan and check the advisory sources for the proposed version.
3. **Maintenance**: the project should have recent releases and a responsive maintainer community. Libraries with no release in over 24 months, a single maintainer or an archived repository should be avoided or accompanied by a risk note.
4. **Provenance**: obtain the library from the approved internal package mirror or the official registry, verify the package name carefully to avoid look-alike names, and pin an exact version with a checksum or lock file.
5. **Fit and size**: prefer a small library that does one thing over a large framework used for one function. Compare with the standard library and existing approved dependencies to avoid duplicates.
6. **Data handling**: confirm that the library does not send telemetry or data to external services without consent. A library that handles personal data or authentication logic needs a Security Champion review.

Where the change introduces a library shared by several teams or a framework expected to last more than 12 months, an Architecture Decision Record may be required (see ENG-001 for engineering standards and the ADR process).

6. The Open Source Review Board

6.1 How to request approval

The engineer submits a NorthDesk request using the open-source review form, with the details in section 4.2. The OSRB reviews requests as they arrive and aims to respond within 5 business days of a complete request. Urgent requests linked to a customer commitment or a security fix may be marked urgent, and the chair then aims for a decision within 2 business days. Incomplete requests are returned to the requester.

6.2 Decisions and records

The OSRB's decision is Approved, Approved with conditions, Rejected or More information needed. Decisions are recorded in the central open-source register with the library, version range, licence, conditions, approver and date. An approval applies to the stated version range and use. A major version upgrade, a change of licence by the upstream project or a new way of using the library requires a new review. The register is searchable by all engineers so that a team does not need to ask again for a library already approved in the same way.

6.3 Licence changes upstream

When an upstream project changes its licence, for example from an allowed licence to a restrictive one, the team must stop upgrading beyond the last allowed version, notify the Principal Architect, and plan replacement or migration within a period set by the OSRB, normally no longer than 90 days. The Security Champion should check whether security fixes remain available for the older version.

7. Software Bill of Materials

An SBOM must be generated for every release of every product and service. NorthShip creates the SBOM automatically from the lock files and build artefacts at the release stage, in a standard machine-readable format, and attaches it to the release record. A release with a missing SBOM cannot pass the release gate. The SBOM must list each component, its version, its licence and its source, including container base images and transitive dependencies.

SBOMs are retained with the release record for as long as the release is supported. For the Nexus Platform that means at least until the end of the version's support period: for example the 5.0 LTS release is supported until 10 February 2028, so its SBOM must be kept until then. The SBOM allows Security Operations to answer quickly which products are affected when a new vulnerability is announced.

For customers who request one, Customer Success may provide an SBOM summary after approval from the Principal Architect, without internal repository paths or system names.

8. Vulnerability Management for Dependencies

Dependency vulnerabilities are handled using the remediation timelines in the approved security documents. The deadlines count from detection and triage.

Severity (CVSS)	Remediation deadline
Critical (9.0 to 10.0)	72 hours
High (7.0 to 8.9)	14 days
Medium (4.0 to 6.9)	30 days
Low	90 days
Actively exploited	Mitigation within 24 hours

Remediation means upgrading to a fixed version, replacing the library, or applying a mitigation approved by the Security Champion. If a fix is not yet available, the team may request a risk acceptance from the CISO delegate, which has an expiry of no more than 90 days. Dependency scans run in the NorthShip pipeline on every build, and a full scan of all repositories runs weekly. A build that adds a new dependency with an unpatched critical vulnerability must fail the gate.

Teams should also keep dependencies reasonably current. As a guide, direct dependencies should not be more than one major version behind, and abandoned libraries should be replaced within two quarters. Such upgrade work is normal maintenance and may be recorded in the team backlog.

9. Using Code from the Internet

Copying code from public sites, forums, AI assistants or other sources into the Northstar code base is allowed only if the licence is in the allowed category or the OSRB has approved it. Code with no licence is prohibited. Only AI coding tools on the Approved AI Tools list may be used, and no Confidential or Restricted data may be sent to external AI tools. Engineers remain responsible for the licence and security quality of any code suggested by a tool. Snippets longer than a few lines taken from a public source must carry a comment recording the origin and licence.

10. Contributing to Open Source

Employees may contribute to external open-source projects in a work capacity only with their manager's approval and a short review from the Principal Architect to confirm that no confidential information, customer data, credentials or proprietary code is included. The contribution must be made under the project's standard contributor terms, and the employee must use a company or personal identity as agreed with the manager. Contributions of substantial size, or releasing a Northstar project as open source, need General Counsel approval and, for new projects, an ADR. Contributions in personal time that are unrelated to Northstar's business and use no company resources do not need approval, but must not include Northstar code or information.

11. Worked Examples

Example 1: allowed licence. An engineer on the Nexus Insight team wants to add a charting library under the MIT licence to an internal dashboard. The licence is on the allowed list, the dependency scan shows no critical vulnerabilities and the library has regular releases. No approval is needed. The engineer notes the licence in the pull request, and the SBOM generated at release records it.

Example 2: MPL-2.0 library. A team building a Nexus Connect connector wants a parsing library under MPL-2.0 and plans to ship it unmodified, dynamically linked, in a customer-installed connector package. MPL-2.0 is in the review category, so the engineer files an OSRB request with

the linking and distribution details. The OSRB approves with the condition that Northstar does not modify the library's files, and records the approval in the register. The team merges the change after the approval.

Example 3: GPL library in a distributed product. An engineer finds a convenient GPL-licensed encoding library and wants to bundle it with the on-premises agent shipped to Enterprise customers. GPL in a distributed product is prohibited. The reviewer rejects the pull request and suggests an Apache-2.0 alternative. No OSRB request is needed because the licence is prohibited, not reviewable.

Example 4: critical vulnerability. During a weekly scan, Security Operations finds a Critical vulnerability (CVSS 9.8) in a JSON library used by a Tier-1 service. The deadline is 72 hours from triage. The team upgrades to the fixed version, the change is released in the next production deployment window as a normal change. If the vulnerability were reported as actively exploited, the team would have to apply a mitigation within 24 hours using the emergency change route.

Example 5: no licence. A developer wants to reuse a 200-line parsing utility from a public repository that has no licence file. Code without clear terms is prohibited, so the utility must not be copied. The developer writes the function from scratch or picks an allowed library instead.

Example 6: new dependency with an unpatched critical vulnerability. A team wants to use version 2.1 of an HTTP client library under Apache-2.0, but the scan shows an unpatched critical vulnerability in that version. A new dependency may not be added with an unpatched critical vulnerability, so the team uses version 2.2, which carries the fix, or chooses a different library.

12. Exceptions and Escalation

Exceptions to the licence rules may be granted only by the OSRB with the Legal representative's written agreement, and only for the prohibited category when a documented business case exists, such as a customer contract requiring a specific component, and the General Counsel also approves. An exception must have an expiry date, a plan to remove the dependency and a record in the open-source register. Exceptions to vulnerability deadlines follow the CISO delegate risk acceptance route and expire within 90 days.

Suspected breaches of this policy, such as a prohibited licence found in a released product, must be reported to the Principal Architect and the Legal representative immediately. The release manager may suspend the release, and the team must remove or replace the component under a plan agreed with Legal. Where the issue affects customers, the VP Engineering and General Counsel decide on customer communication. Disciplinary action under the standard disciplinary process may apply to deliberate circumvention.

13. Frequently Asked Questions

Which licences can I use without approval? MIT, Apache-2.0, BSD-2-Clause, BSD-3-Clause and ISC.

Which licences need review? LGPL, MPL-2.0 and EPL need approval from the Open Source Review Board before use.

Which licences are banned? AGPL, SSPL, GPL in distributed products, and any licence without clear terms.

Is an SBOM required for internal tools? An SBOM must be generated for every release, which includes internal services released through NorthShip.

Can a developer machine tool be GPL? Yes in many cases, provided nothing from it ships in the product, but the use should be noted in the pull request.

How fast does the OSRB respond? The aim is 5 business days for complete requests and 2 business days for urgent ones.

14. Related Documents

- ENG-001 contains the engineering standards for code review and releases that include the dependency checks in this policy.
- SEC-007 and SEC-011 contain the approved security rules for vulnerability management and third-party risk that complement this policy.

15. Revision History

Version	Date	Change
1.0	2023-11-20	First approved policy
1.3	2024-09-02	Added SBOM requirement and review timelines
1.4	2025-04-01	Clarified GPL use in build tools and upstream licence changes